École Nationale des Sciences Appliquées de Béni Mellal

Université Sultan Moulay Slimane

Filière : Intelligence Artificielle et Cybersécurité

Module : Administration Sécurisée et Forensics (ASF)

Rapport Forensique

Détection et Analyse d'une Compromission sur un Serveur Linux

---

Encadrant : Pr. TOUIL

Étudiante : LATOUTI Hassnae

Environnement : VM1 Ubuntu 22.04 LTS / VM2 Kali Linux 2024

Année universitaire : 2025 – 2026

Contents

1 Description de l'Incident **2**
1.1 Contexte général . . . 2
1.2 Environnement de simulation . . . 2

2 Méthodologie **3**
2.1 Étape 0 — Préparation . . . 4
2.2 Étape 1 — Modèle de menace . . . 4
2.3 Étape 2 — Hardening . . . 6

3 Preuves Extraites (Logs) **8**
3.1 Mise en place de la journalisation . . . 8
3.2 Simulation d'attaque — Préparation Kali . . . 10
3.3 Bruteforce SSH avec Hydra . . . 11
3.4 Connexion SSH et actions malveillantes . . . 12
3.5 Détection et analyse forensique . . . 16

4 Chronologie de l'Attaque **19**

5 Impact de la Compromission **20**
5.1 Indicateurs de Compromission (IOC) . . . 20
5.2 Évaluation de l'impact . . . 21

6 Réponse à Incident **21**

7 Recommandations **25**

Conclusion **25**

1. Description de l'Incident

Cette section présente le contexte de l'incident détecté, les signaux d'alerte identifiés ainsi que l'environnement de simulation utilisé pour reproduire et analyser l'attaque.

1.1. Contexte général

Description de la situation initiale du serveur cible et des premiers indices d'une compromission observés par les équipes de sécurité.

Une organisation dispose d'un serveur Linux (Ubuntu 22.04 LTS) accessible sur un réseau interne. Plusieurs signaux d'alerte ont été détectés :

- Connexions SSH à des horaires inhabituels depuis l'IP `192.168.56.20`
- Création d'un compte utilisateur suspect (`backdoor`) sans justification
- Activité réseau sortante anormale (connexion vers le port 8080)
- Présence d'une clé SSH injectée dans `/root/.ssh/authorized_keys`

1.2. Environnement de simulation

Deux machines virtuelles interconnectées via VMnet1 (Host-only) ont été utilisées : VM1 joue le rôle du serveur victime sous Ubuntu 22.04 LTS, et VM2 représente la machine attaquante sous Kali Linux 2024.

Machine	Système	Adresse IP	Rôle
VM1	Ubuntu 22.04 LTS	192.168.56.10	Serveur victime
VM2	Kali Linux 2024	192.168.56.20	Machine attaquante

Table 1: Environnement — réseau VMnet1 (Host-only)

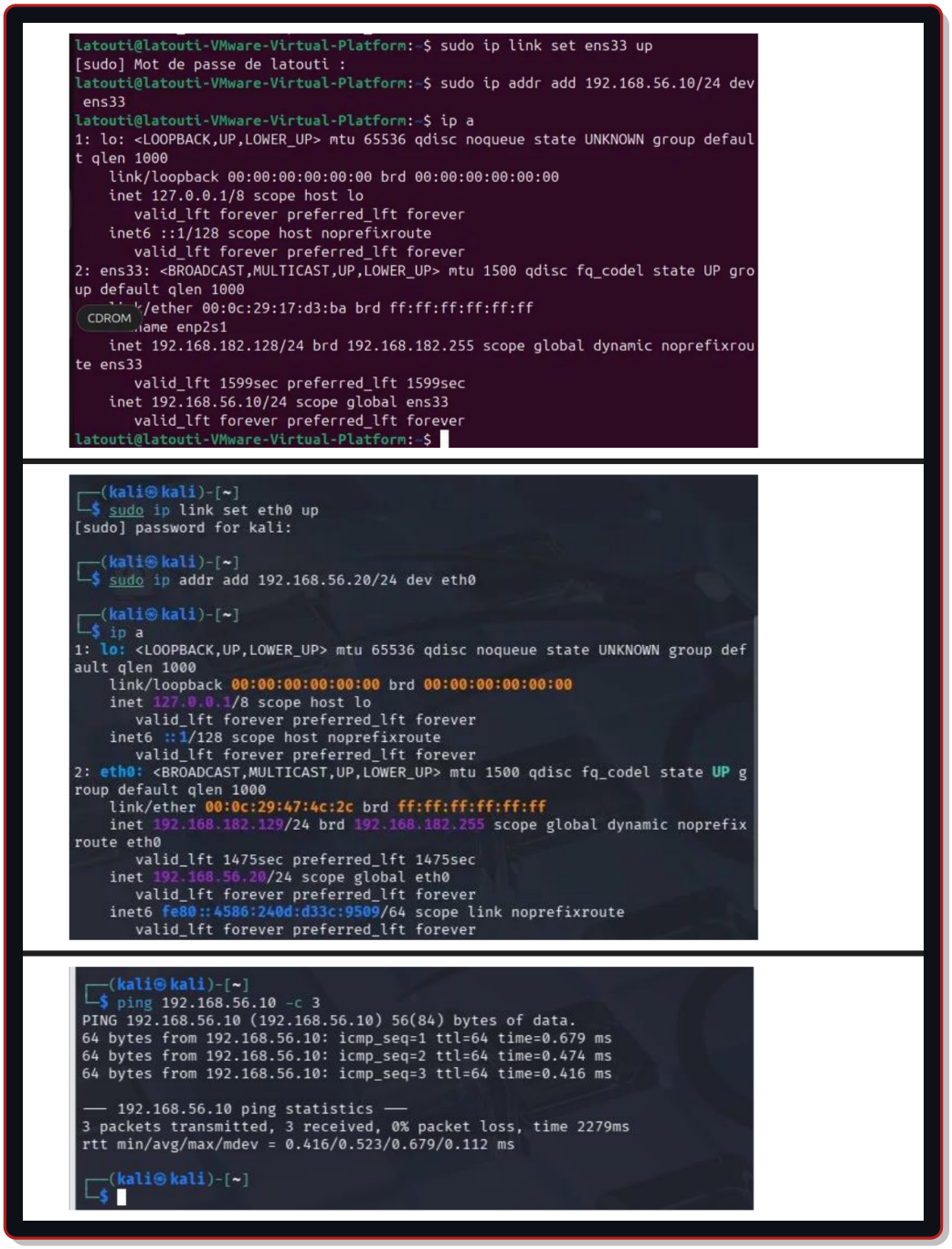


Figure 1: *Configuration IP des deux VMs — Ubuntu (192.168.56.10) et Kali (192.168.56.20) sur VMnet1*

2. Méthodologie

La méthodologie adoptée suit une approche structurée en trois étapes : préparation de l'environnement, identification du modèle de menace, puis durcissement de la configuration du serveur avant de simuler l'attaque.

2.1. Étape 0 — Préparation

Installation des outils de sécurité et de surveillance sur le serveur Ubuntu (net-tools, auditd, ufw, chrony, fail2ban) et vérification de la disponibilité de Hydra sur la machine Kali pour la phase d'attaque.

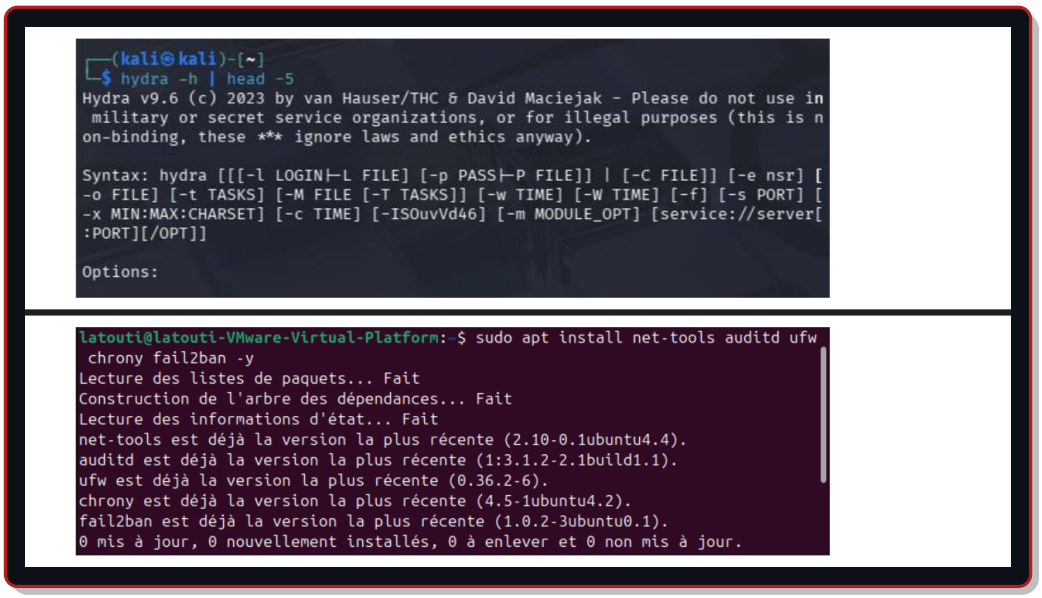


Figure 2: *Installation des outils sur Ubuntu : net-tools, auditd, ufw, chrony, fail2ban — et vérification Hydra sur Kali*

2.2. Étape 1 — Modèle de menace

Recensement de la surface d'attaque du serveur : état du service SSH, liste des utilisateurs actifs, ports réseau ouverts, permissions des fichiers sensibles (`/etc/passwd`, `/etc/shadow`, `sudoers`) et configuration initiale de sshd.

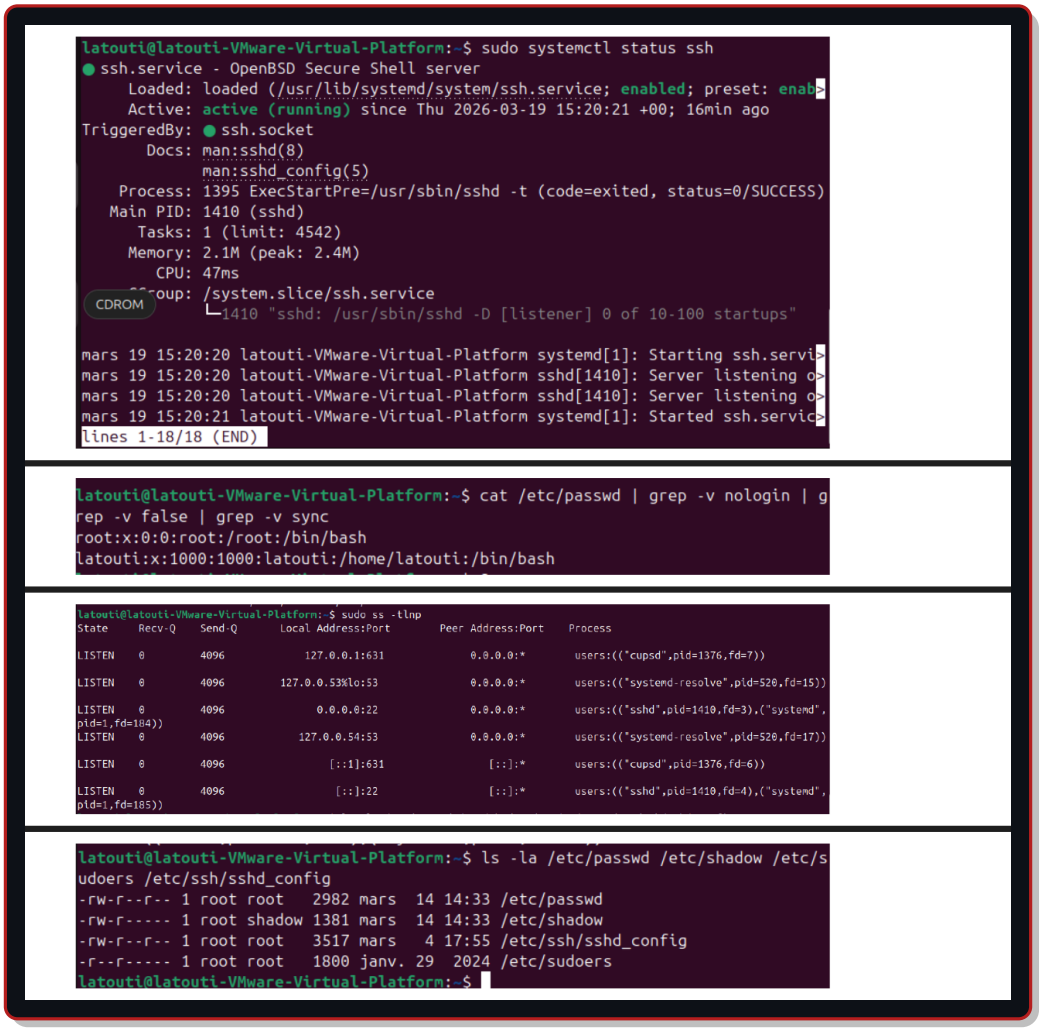


Figure 3: *SSH actif (active running), liste des utilisateurs, services réseau (port 22 ouvert), fichiers sensibles*

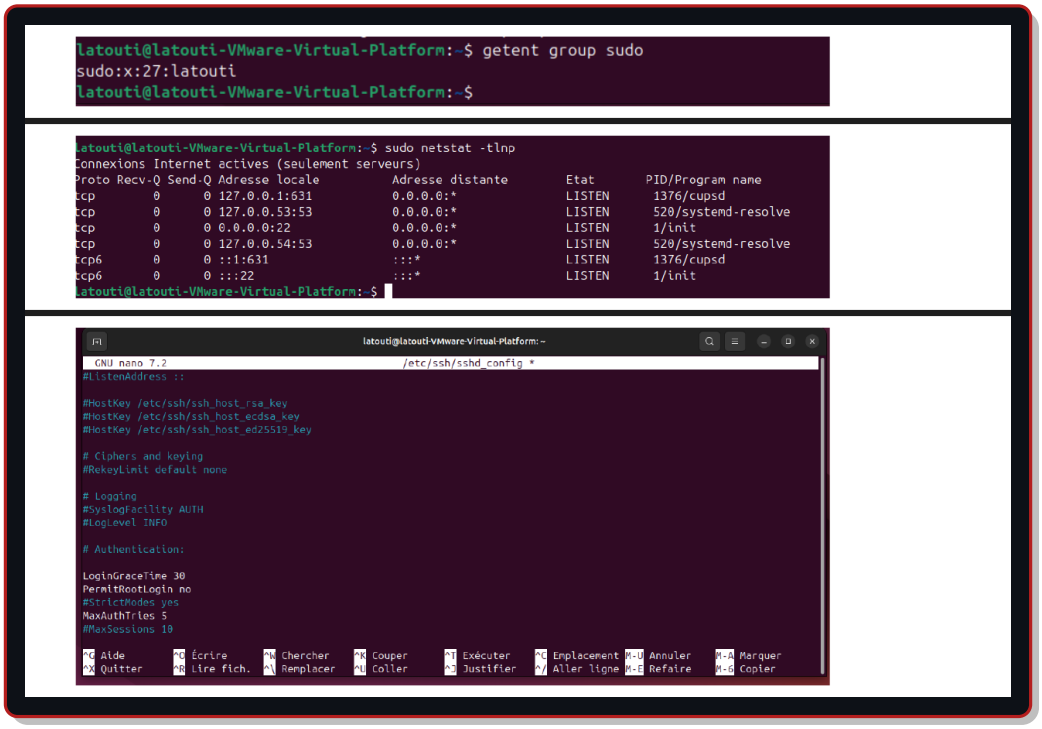


Figure 4: *Accès sudo (getent group sudo), netstat, et modification de sshd_config (PermitRootLogin no, MaxAuthTries 5)*

2.3. Étape 2 — Hardening

Renforcement de la sécurité du serveur : redémarrage de SSH avec la nouvelle configuration, création du compte de test `alice`*, activation du pare-feu UFW restreint au sous-réseau* `192.168.56.0/24`*, configuration des mises à jour automatiques et activation de rsyslog.*

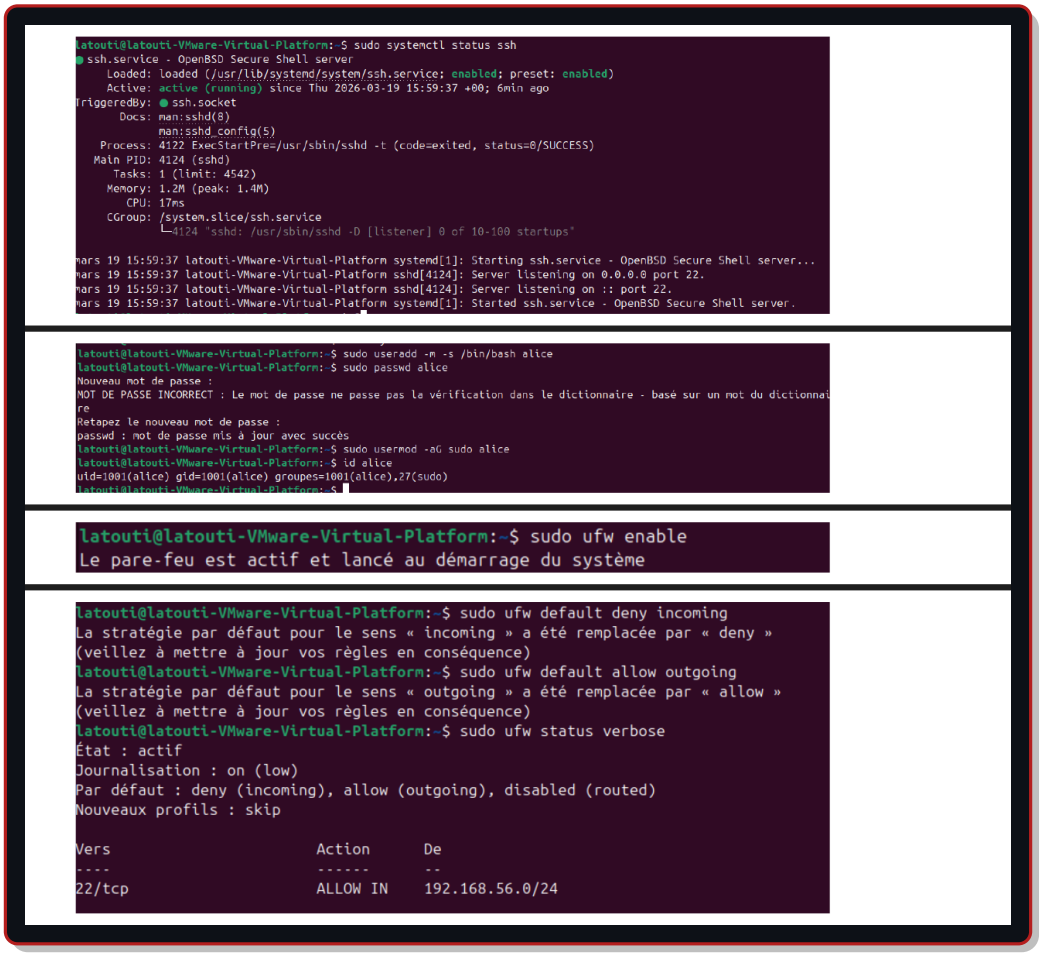


Figure 5: *Redémarrage SSH, création du compte alice (password123), activation UFW avec règle SSH depuis 192.168.56.0/24*

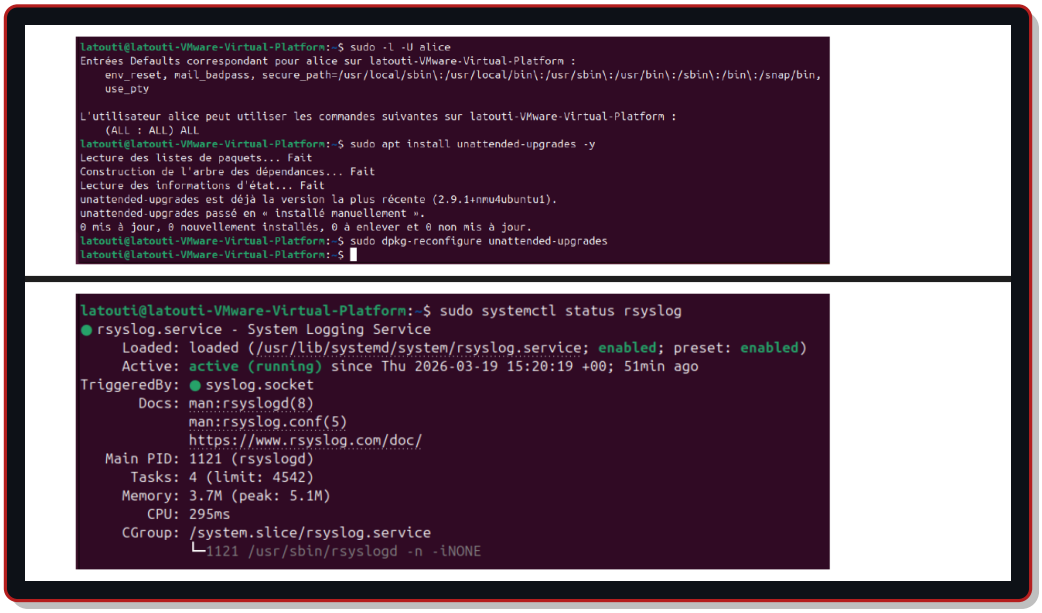


Figure 6: *Droits sudo d'alice, mises à jour automatiques (unattended-upgrades), rsyslog actif*

3. Preuves Extraites (Logs)

Cette section documente l'ensemble des preuves collectées lors de la simulation : journaux d'authentification, traces auditd, résultats Hydra et logs des actions malveillantes. Ces éléments constituent le cœur de l'analyse forensique.

3.1. Mise en place de la journalisation

Avant de lancer l'attaque, un dispositif de journalisation complet est mis en place : consultation de `auth.log`*, activation et démarrage du démon* `auditd`*, puis ajout de règles de surveillance sur les fichiers critiques (*`/etc/passwd`*,* `/etc/shadow`*,* `sudoers`*) et les appels système réseau et exécution.*

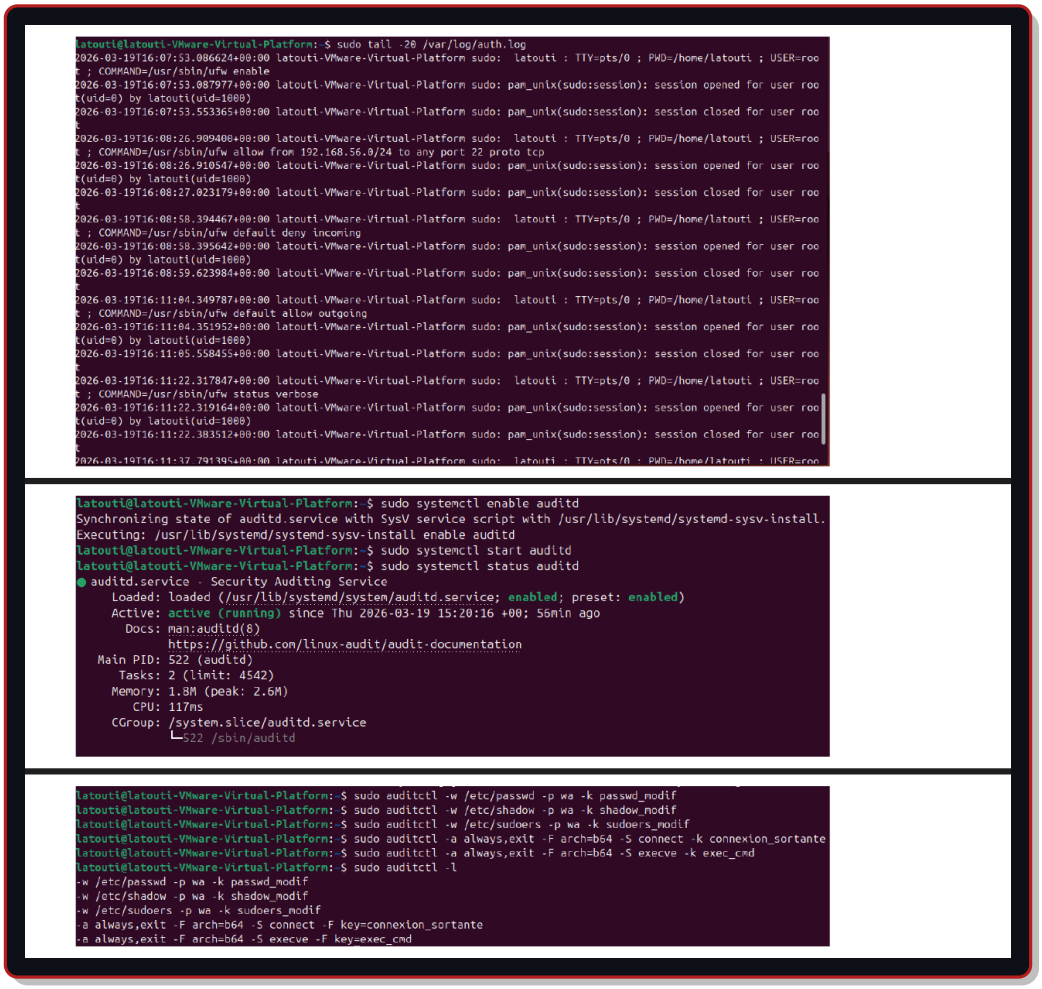


Figure 7: *Consultation de auth.log, activation auditd, et ajout des règles de surveillance (passwd, shadow, sudoers, connect, execve)*

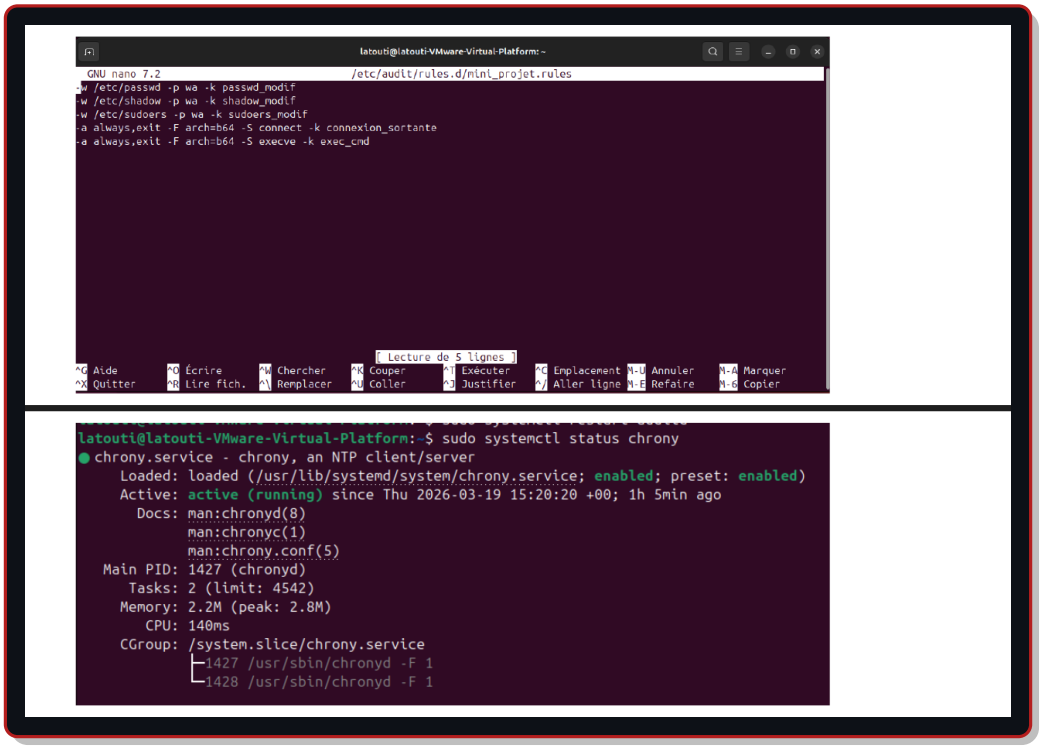


Figure 8: *Règles auditd persistantes dans mini_ projet.rules et chrony actif (synchronisation NTP)*

3.2. Simulation d'attaque — Préparation Kali

Création d'une wordlist personnalisée sur la machine Kali contenant des mots de passe courants. Cette liste sera utilisée par Hydra pour tenter de compromettre le compte `alice` *par force brute via SSH.*

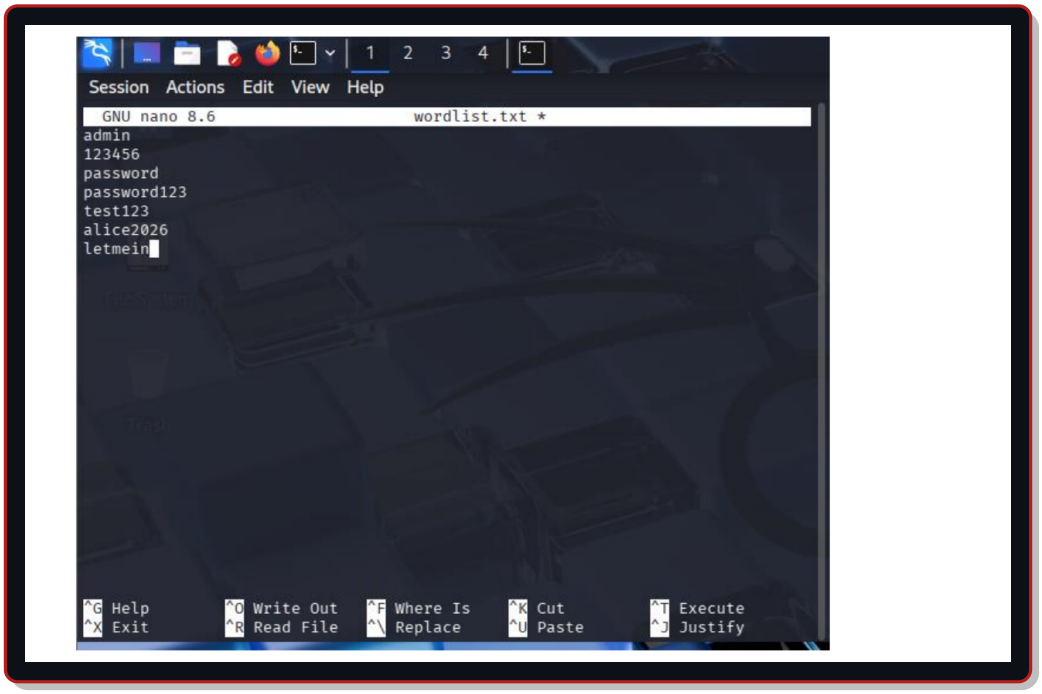


Figure 9: *Création et vérification de la wordlist sur Kali (admin, 123456, password, password123, test123, alice2026, letmein)*

3.3. Bruteforce SSH avec Hydra

Lancement de l'attaque par force brute avec Hydra v9.6 en ciblant le service SSH du serveur victime. Le mot de passe du compte `alice` *est découvert en seulement 3 secondes, illustrant la faiblesse d'un mot de passe de dictionnaire.*

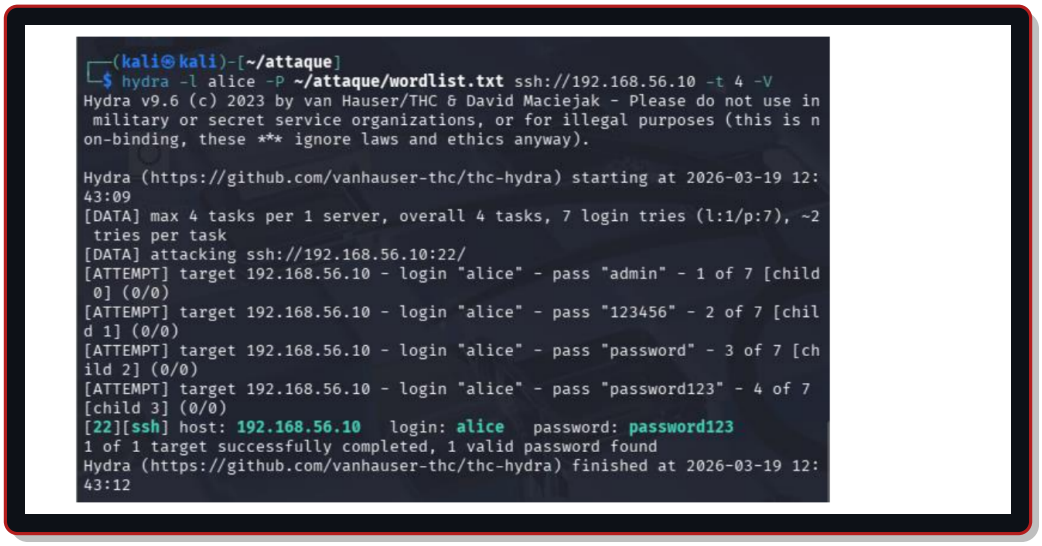


Figure 10: *Hydra v9.6 — Bruteforce SSH réussi : login alice, password* ***password123*** *trouvé en 4 tentatives (12:43:09 → 12:43:12)*

Mot de passe compromis

Compte : alice **Mot de passe :** password123 **IP source :** 192.168.56.20
Le mot de passe a été trouvé en **3 secondes** par Hydra.

3.4. Connexion SSH et actions malveillantes

Une fois le mot de passe obtenu, l'attaquant se connecte en SSH avec le compte `alice`*, exploite ses droits sudo pour élever ses privilèges à* `root`*, crée un compte backdoor, exfiltre des données sensibles et installe une persistance via clé SSH.*

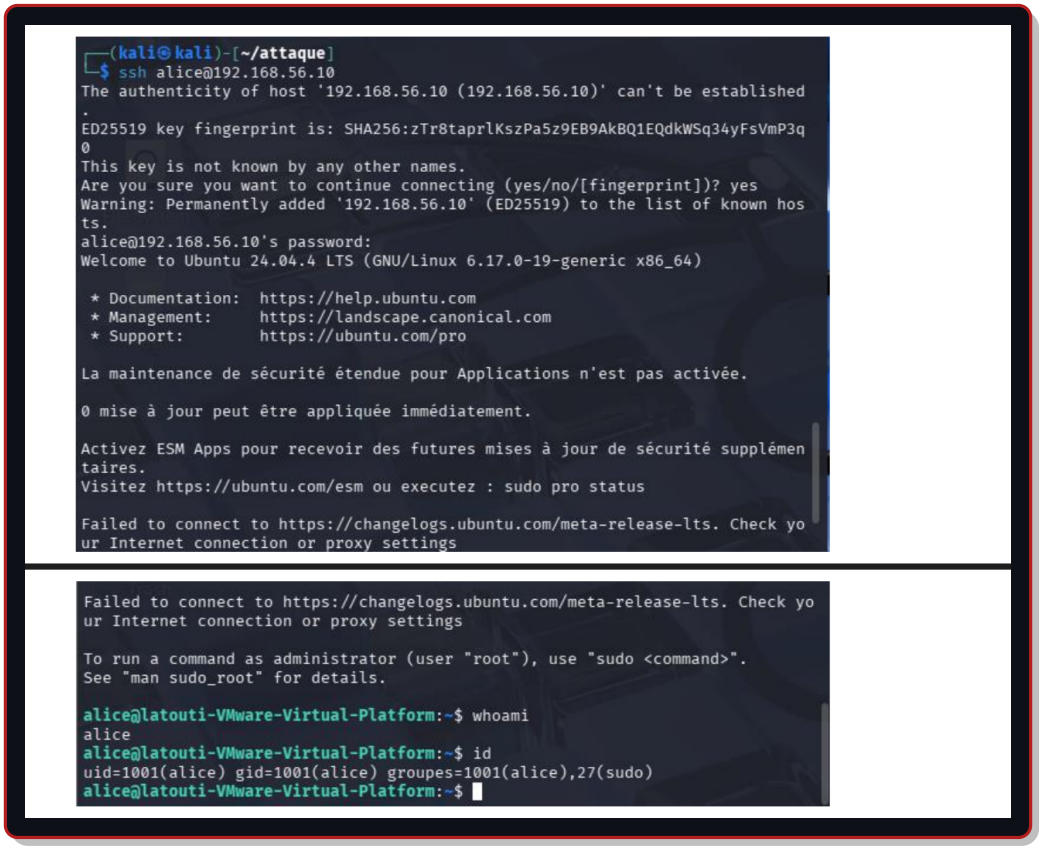


Figure 11: *Connexion SSH réussie avec alice depuis Kali — whoami=alice, id montre les droits sudo*

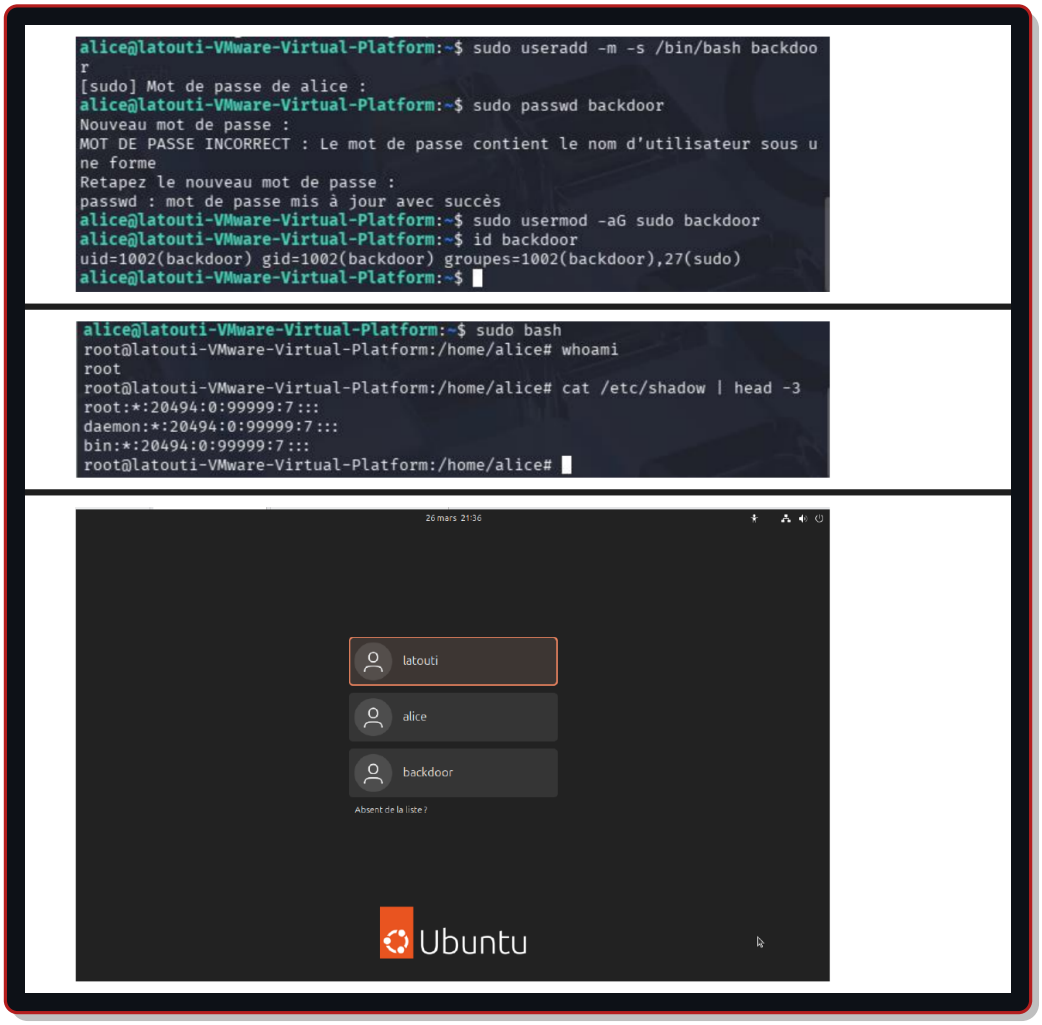


Figure 12: *Création du compte backdoor (uid=1002, sudo), élévation root (sudo bash, whoami=root), lecture de /etc/shadow*



Figure 13: *Connexion sortante simulée (nc -lvnp 8080 sur Kali reçoit la connexion de VM1), génération de la paire de clés SSH backdoor*

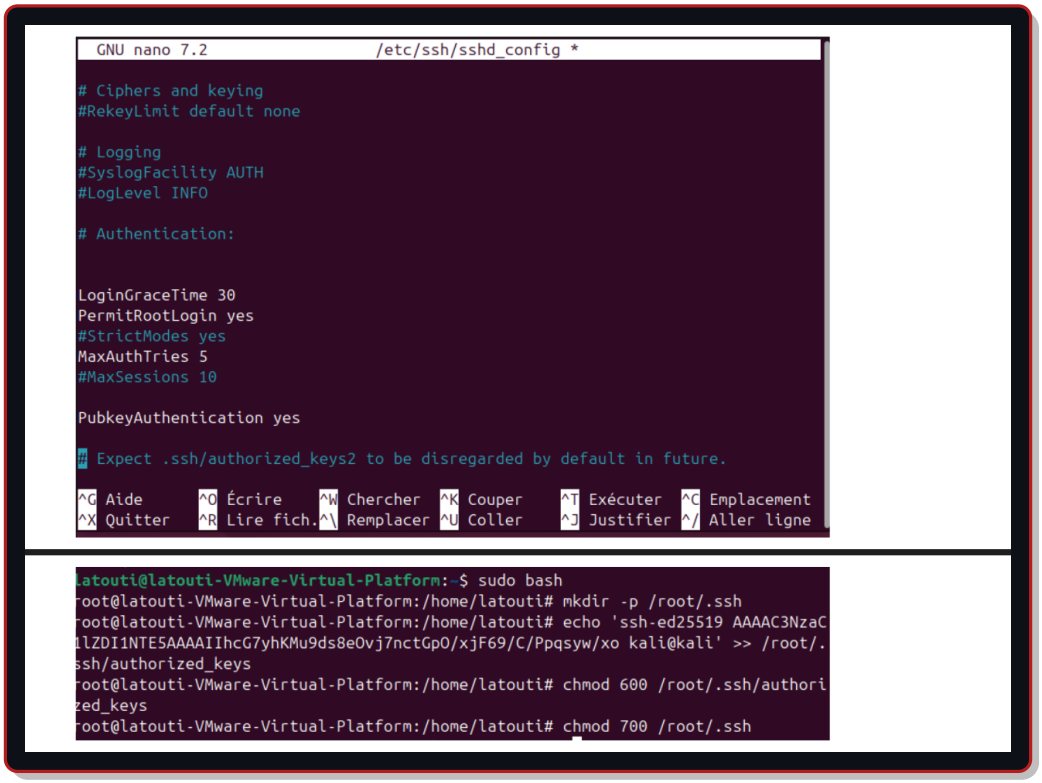


Figure 14: *Modification sshd_config (PermitRootLogin yes, PubkeyAuthentication yes) et injection de la clé SSH dans /root/.ssh/authorized_keys*

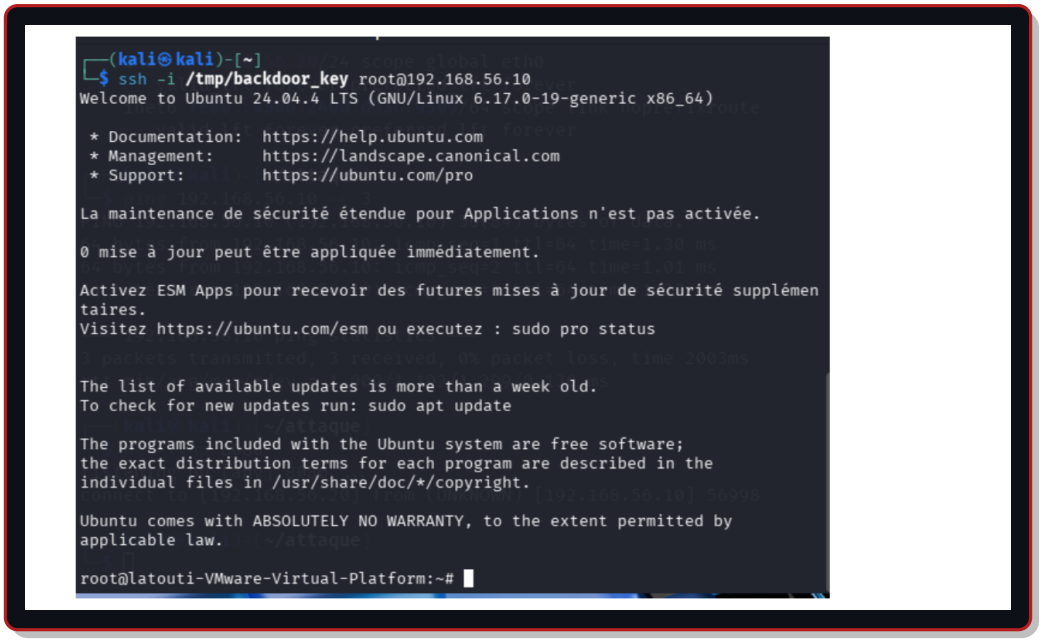


Figure 15: *Accès root SANS mot de passe depuis Kali via la clé SSH injectée — persistance totale établie*

Compromission totale

L'attaquant dispose d'un accès **root sans mot de passe** via clé SSH. La compromission est totale et persistante.

3.5. Détection et analyse forensique

Analyse des journaux collectés pour reconstituer l'ensemble des actions de l'attaquant : recherche des tentatives de connexion échouées dans `auth.log`*, interrogation d'auditd via* `ausearch` *et génération de rapports d'authentification avec* `aureport`*.*

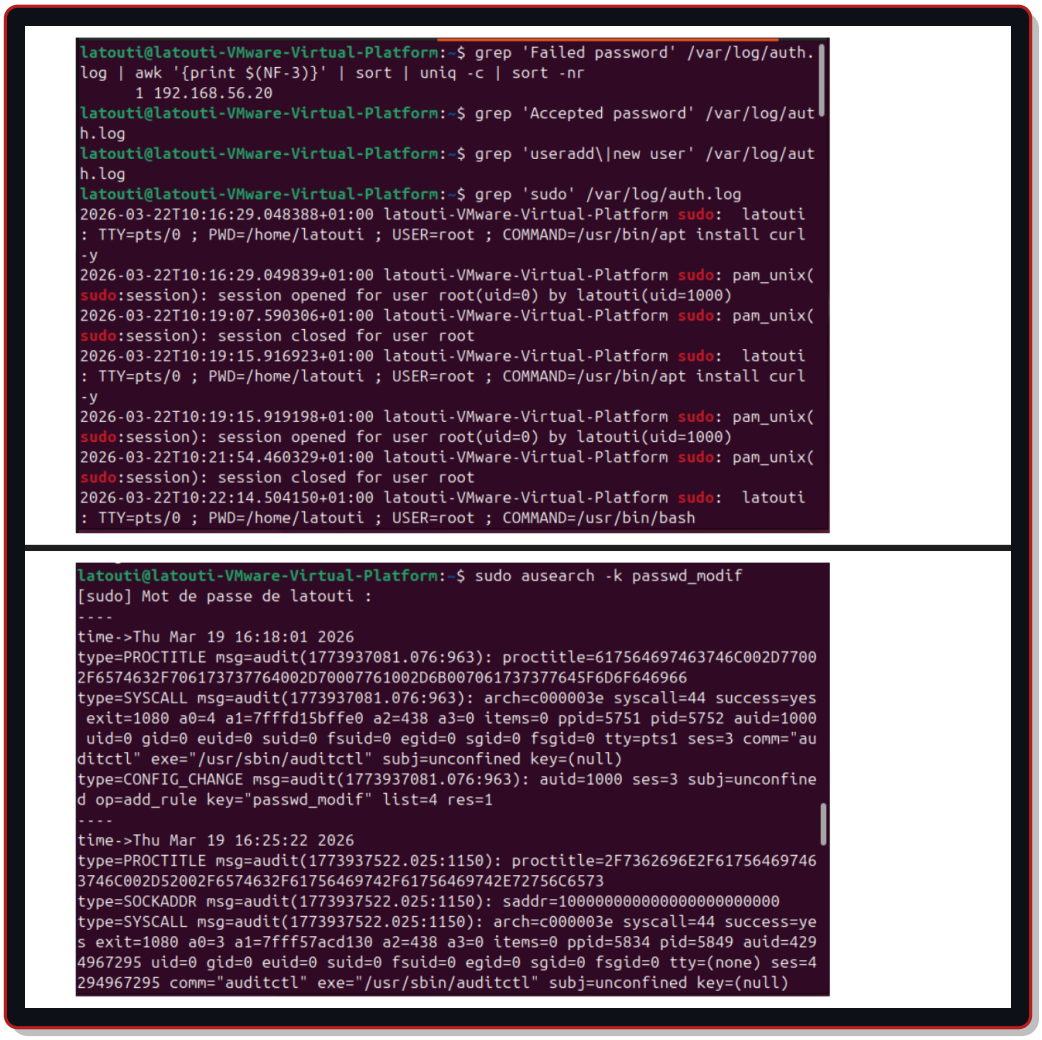


Figure 16: *Détection dans auth.log : tentatives bruteforce depuis 192.168.56.20, commandes sudo suspectes, et résultats ausearch passwd_ modif*

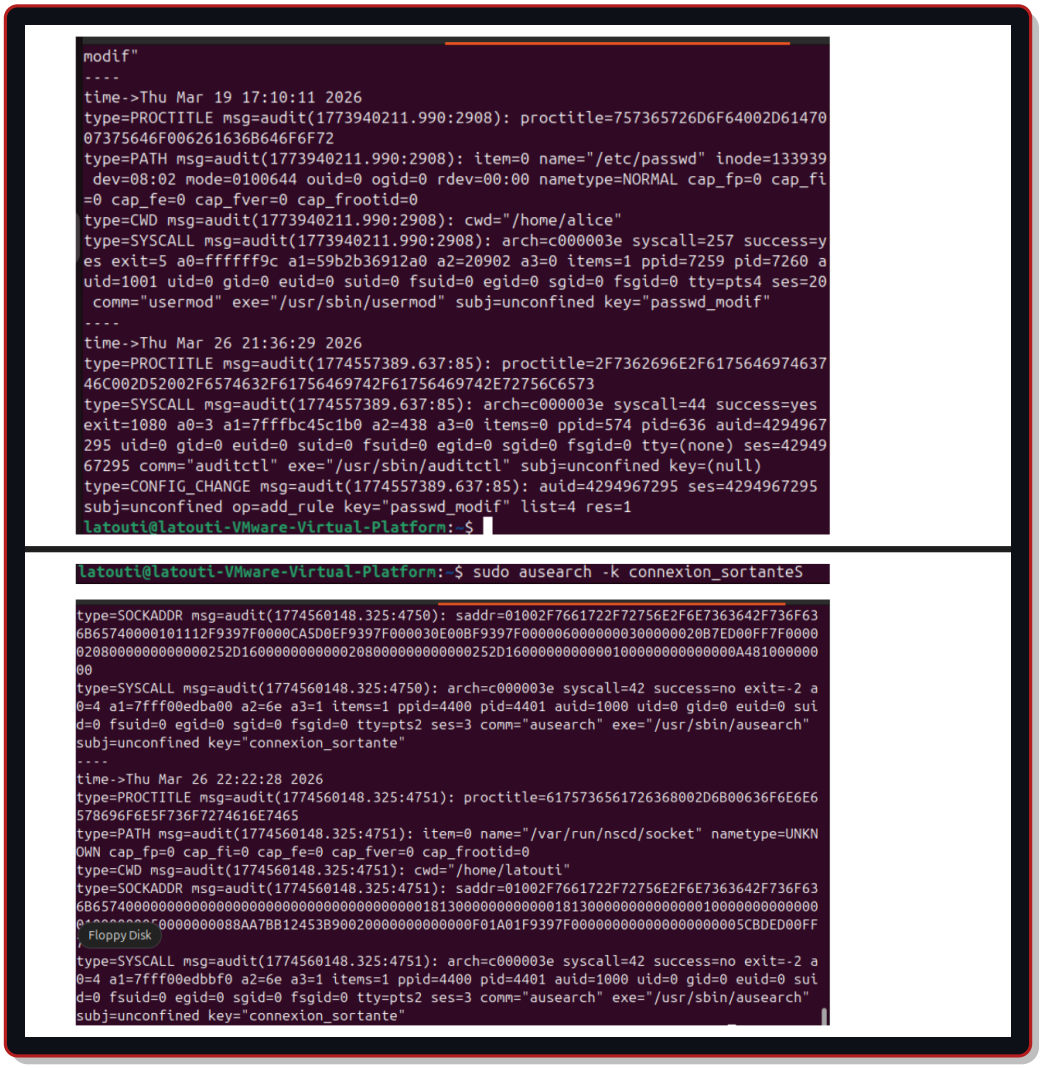


Figure 17: *ausearch -k connexion_ sortante : connexions réseau suspectes détectées par auditd*

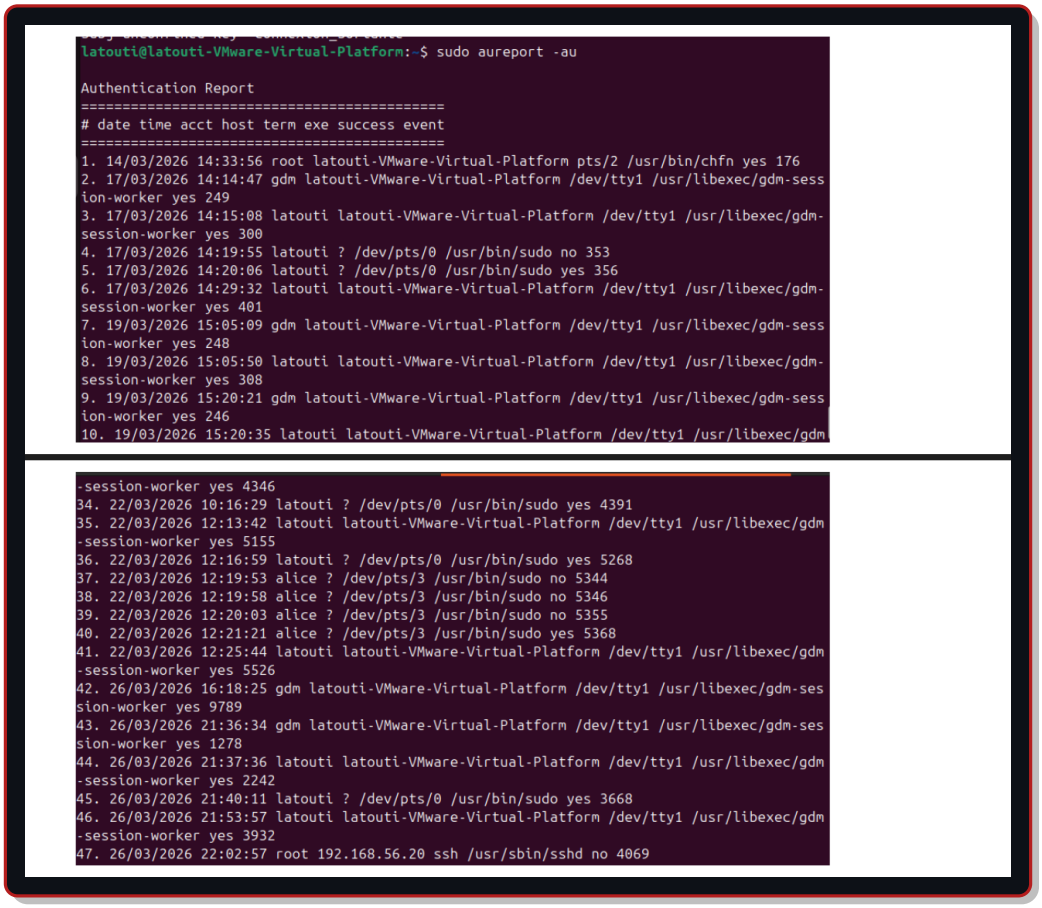


Figure 18: *aureport -au : rapport d'authentification complet — tentatives alice (succès/échecs), accès root depuis 192.168.56.20*

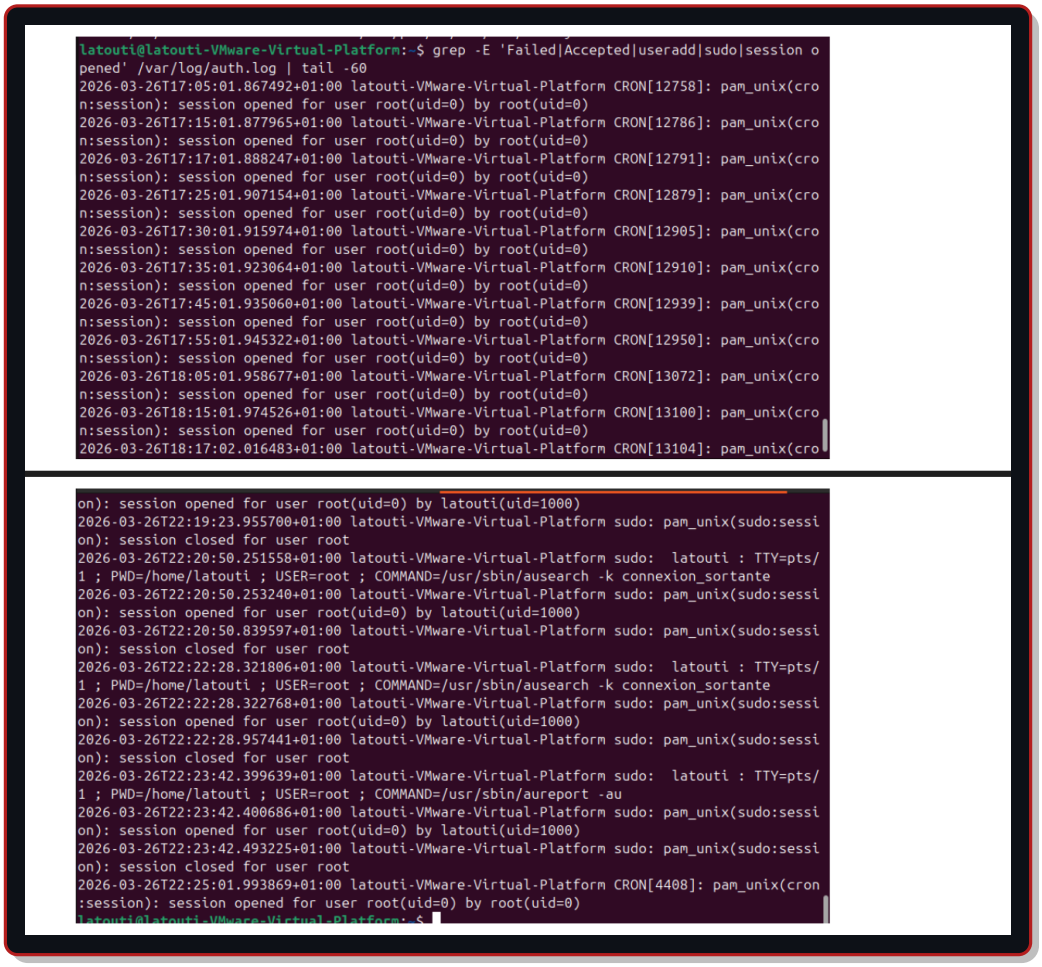


Figure 19: *Chronologie complète dans auth.log : sessions CRON, commandes sudo, événements forensiques reconstituables*

4. Chronologie de l'Attaque

Reconstruction temporelle complète des événements de la compromission, depuis le premier essai de bruteforce jusqu'à l'établissement d'un accès root persistant sans mot de passe, avec le niveau de sévérité associé à chaque phase.

Horodatage	Phase	Action	Sévérité
2026-03-19 12:43:09	Bruteforce	Hydra démarre l'attaque SSH sur alice	MOYENNE
2026-03-19 12:43:12	Bruteforce	Mot de passe trouvé : `password123`	HAUTE
2026-03-19 12:43:xx	Accès initial	Connexion SSH alice depuis 192.168.56.20	HAUTE
2026-03-22 12:21:21	Backdoor	Création compte backdoor (uid=1002, sudo)	HAUTE
2026-03-22 xx:xx:xx	Escalade	sudo bash → whoami=root	CRITIQUE
2026-03-22 xx:xx:xx	Exfiltration	nc -zv 192.168.56.20 8080 (connexion sortante)	HAUTE
2026-03-22 xx:xx:xx	Persistance	Clé SSH injectée dans /root/.ssh/authorized_keys	CRITIQUE
2026-03-26 22:02:57	Persistance	Accès root sans mot de passe via clé SSH	CRITIQUE

Table 2: Chronologie des événements de la compromission

5. Impact de la Compromission

Évaluation des conséquences de l'attaque sur le système compromis selon les trois piliers de la sécurité : confidentialité, intégrité et disponibilité, complétée par un inventaire des indicateurs de compromission (IOC) identifiés.

5.1. Indicateurs de Compromission (IOC)

Liste des artefacts techniques laissés par l'attaquant et servant de preuves numériques : adresses IP sources, comptes créés, outils utilisés, fichiers modifiés et connexions suspectes détectées dans les journaux.

Type	Valeur	Criticité
IP Source	192.168.56.20 (Kali Linux)	CRITIQUE
Compte compromis	alice (uid=1001, sudo)	HAUTE
Compte malveillant	backdoor (uid=1002, sudo)	CRITIQUE
Clé SSH	/root/.ssh/authorized_keys (ed25519)	CRITIQUE
Outil attaque	Hydra v9.6 (bruteforce SSH)	HAUTE
Connexion suspecte	nc -zv 192.168.56.20 8080	HAUTE
Fichier lu	/etc/shadow par root compromis	CRITIQUE

Table 3: Indicateurs de Compromission identifiés

5.2. Évaluation de l'impact

Analyse de l'impact réel de la compromission sur les quatre dimensions fondamentales de la sécurité du système d'information : confidentialité des données, intégrité du système, disponibilité du service et persistance de l'accès malveillant.

1. **Confidentialité** : Accès total à `/etc/shadow` (hachages des mots de passe)
2. **Intégrité** : Création de compte non autorisé, modification de `/etc/passwd`, injection de clé SSH
3. **Disponibilité** : Potentiel de déni de service, backdoor permanent
4. **Persistance** : Accès root sans mot de passe — l'attaquant peut revenir à tout moment

6. Réponse à Incident

Actions de remédiation immédiate entreprises pour neutraliser la compromission : blocage de l'IP attaquante via UFW, suppression du compte backdoor, réinitialisation des mots de passe compromis, suppression de la clé SSH injectée et déploiement de Fail2Ban pour prévenir de futures attaques par force brute.

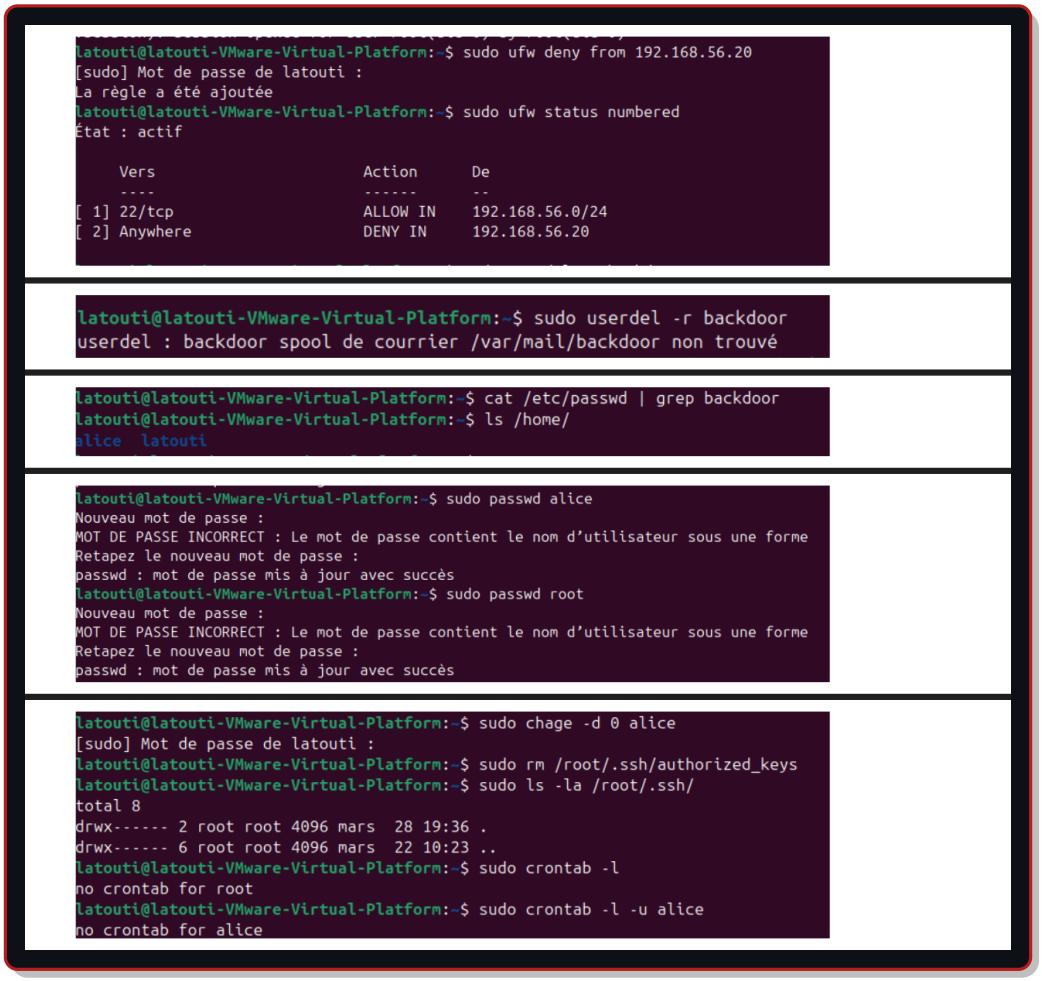


Figure 20: *Réponse à incident : UFW bloque 192.168.56.20, suppression backdoor, changement mots de passe alice et root, suppression clé SSH, vérification crons*

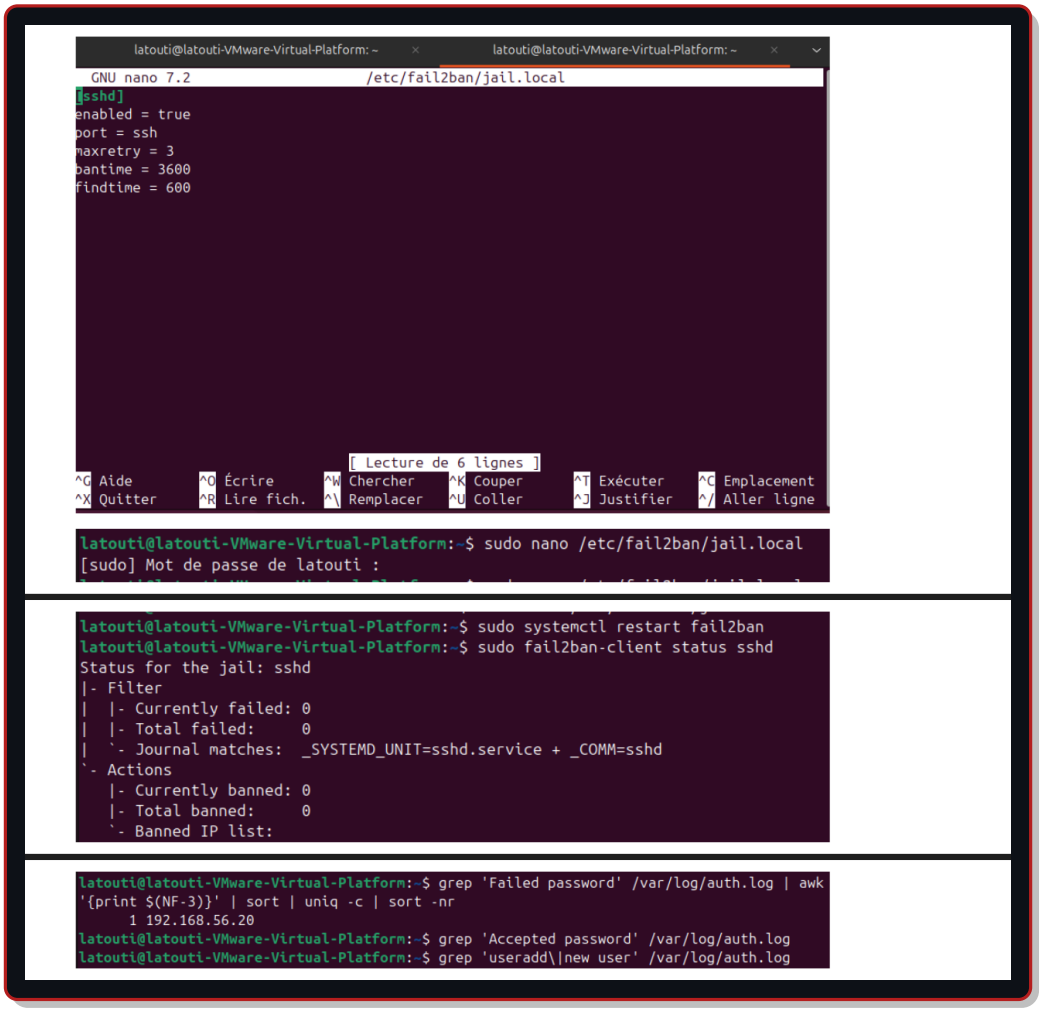


Figure 21: *Configuration Fail2Ban (maxretry=3, bantime=3600), statut sshd actif, et vérification grep des logs après remédiation*

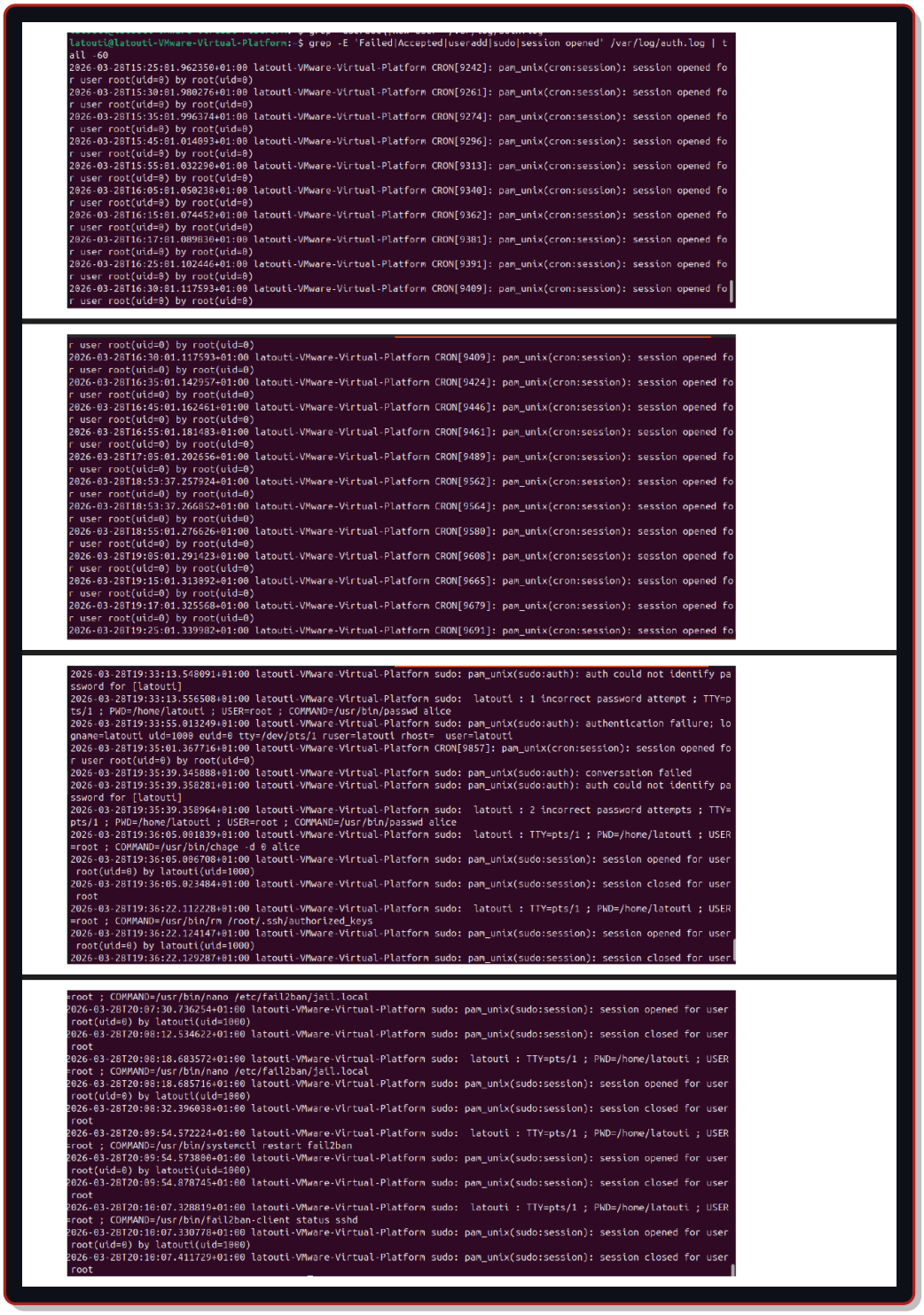


Figure 22: *Logs auth.log confirmant les actions de remédiation : rm authorized_keys, nano jail.local, restart fail2ban, fail2ban-client status*

Serveur sécurisé après remédiation

- **UFW :** IP attaquante bloquée (DENY IN 192.168.56.20)
- **Backdoor :** compte supprimé (userdel -r backdoor)

- **Mots de passe :** alice et root changés avec mots de passe forts
- **Clé SSH :** /root/.ssh/authorized_keys supprimé
- **Crons :** aucune tâche suspecte (no crontab for root/alice)
- **Fail2Ban :** actif (maxretry=3, bantime=3600s)

7. Recommandations

Ensemble de mesures préventives et correctives proposées pour renforcer durablement la sécurité du serveur et éviter toute compromission future. Ces recommandations couvrent la politique de mots de passe, la configuration SSH, la surveillance et la segmentation réseau.

R1. Politique de mots de passe forte : Imposer des mots de passe d'au moins 12 caractères avec `libpam-pwquality`.

R2. Désactiver l'auth par mot de passe SSH : Configurer `PasswordAuthentication no` dans `sshd_config`.

R3. Déployer Fail2Ban : `maxretry=3`, `bantime=3600` sur tous les serveurs SSH.

R4. Surveillance SIEM : Centraliser et corréler les logs de tous les serveurs.

R5. Audit régulier : Vérifier périodiquement les comptes, droits sudo, et clés SSH.

R6. Moindre privilège : Restreindre sudo via `visudo` aux seules commandes nécessaires.

R7. Segmentation réseau : Limiter SSH aux IPs autorisées, utiliser un bastion SSH.

R8. Surveillance sortante : Analyser les logs auditd pour détecter tout reverse shell ou exfiltration.

Conclusion

Ce mini-projet a démontré de manière concrète comment une compromission complète d'un serveur Linux peut être réalisée à partir d'un seul mot de passe faible. En **3 secondes** (12:43:09 → 12:43:12), Hydra a découvert les identifiants du compte `alice`, permettant une escalade vers `root` et l'établissement d'une persistance durable via une clé SSH.

La journalisation mise en place (`auth.log`, `auditd`) a permis de reconstituer fidèlement la chronologie et d'identifier tous les IOC. La réponse à incident a été rapide et efficace.

La sécurité est un processus continu, pas un état final.
Un seul mot de passe faible suffit à compromettre un serveur entier.

Rapport rédigé dans le cadre du Module ASF
ENSA Béni Mellal — Pr. TOUIL — 2025/2026